GREYHAT4HIRE (PTY) LTD

# Phishing Awareness Training

*Protect Yourself — and the Organisation*

POPIA · Cybercrimes Act · NIST SP 800-61 · South Africa

STAFF SECURITY AWARENESS TRAINING

# What We'll Cover Today

1. **What is Phishing?**
   Types and how attackers think
2. **Real-World SA Examples**
   Local threats you need to know
3. **Anatomy of an Attack**
   How to spot a phishing email
4. **Smishing & Vishing**
   Beyond email: SMS and phone attacks
5. **What to Do If You're Targeted**
   Report — Don't Click
6. **POPIA & Your Obligations**
   Legal responsibilities in South Africa
7. **Test Your Knowledge**
   Quick quiz before you go

⏱️ **Duration:** 30–45 minutes

📋 **Mandatory for:**
All staff, contractors, and third parties with access to company systems

⚠️ **Legal basis:**
POPIA Act 4 of 2013 requires organisations to train employees who process personal information

✅ After this session you will be able to:
- Identify phishing attempts
- Know what to do if targeted
- Understand your legal obligations

SECTION 1

# What is Phishing?

# Phishing: The Most Common Cyber Attack

DEFINITION

**Phishing** is a social engineering attack where criminals impersonate trusted entities — banks, SARS, your CEO, or IT department — to trick you into:

- Revealing passwords or credentials
- Clicking malicious links
- Opening infected attachments
- Transferring money or data

**94%**

of malware is delivered via email

**In South Africa:**
Phishing is the #1 initial attack vector. SA saw a **37% increase** in phishing attacks targeting employees in 2023–2024.

# The Many Faces of Phishing

## Email Phishing

Mass-sent fake emails impersonating banks, SARS, FNB, Standard Bank, or your IT department. Low effort — high volume.

## Spear Phishing

Targeted attack using your name, job title, or colleague names. Researched from LinkedIn / social media. Very convincing.

## Whaling

Targets CEOs, CFOs, and directors. Aims to authorise large wire transfers or steal sensitive corporate data.

## Smishing

Phishing via SMS. 'Your ABSA account is suspended — click here.' Common with SA mobile banking customers.

## Vishing

Voice phishing — a 'bank' or 'SAPS officer' calls demanding your OTP or card details.

## Clone Phishing

A real email you previously received is cloned with a malicious link replacing the legitimate one.

# Real South African Phishing Examples

SA FOCUS

## SARS eTax Alert

Subject: 'Your SARS eTax return requires immediate action'
Sender: noreply@sars-tax-refund.co.za
Link leads to fake SARS login page harvesting your SA ID number and banking credentials.

## FNB / ABSA / Nedbank SMS

'Your FNB online banking has been suspended due to suspicious activity. Verify: http://fnb-secure.net/verify'
Plain URL, SMS urgency, fake domain — all red flags.

## CEO Invoice Fraud

Email from 'CEO@yourcompany-sa.com' (note hyphen) to Finance:
'Please process an urgent payment of R450,000 to this new supplier. Keep confidential.' CEO is 'travelling'.

SECTION 2

# Anatomy of a Phishing Email

# 6 Warning Signs in Every Phishing Email

## 1. Suspicious Sender Domain

Check the ACTUAL email address — not the display name. 'ABSA Bank <service@absa-alerts.net>' — that .net domain is fake. Hover, don't trust.

## 2. Urgency & Fear Tactics

'Your account will be closed in 24 hours!' Attackers create panic to stop you thinking clearly. Pause. Verify via official channels.

## 3. Generic Greeting

'Dear Customer' or 'Dear User' instead of your name. Your bank knows your name.

## 4. Suspicious Links

Hover over links before clicking. Does the URL match the official domain? 'paypal-secure-login.com' is NOT PayPal.

## 5. Unexpected Attachments

Unexpected .zip, .doc, .pdf, or .exe attachments — especially invoices or 'HR letters' you weren't expecting.

## 6. Poor Spelling / Grammar

Professional organisations proofread their emails. Typos and broken English are red flags — though well-crafted attacks can look perfect.

# How to Check a Suspicious Link

HANDS-ON

```
https://absa-banking-verify.co.za/account/login?token=abc123
```

**Protocol**

`https://`

Secure = good, but attackers use HTTPS too. Don't trust HTTPS alone.

**Path**

`/account/login`

Login pages in email links are almost always phishing.

**Domain**

`absa-banking-verify.co.za`

FAKE! Real ABSA domain is absa.co.za — hyphens and extra words are red flags.

**Token**

`?token=abc123`

Tracks which target clicked — so attackers know you took the bait.

💡 GOLDEN RULE: When in doubt, go directly to the official website — type it yourself. Never click links in unexpected emails.

SECTION 3

# Smishing, Vishing & Beyond

# Smishing: Phishing via SMS

**Example SMS**

```
ABSA BANK

Your ABSA account has been temporarily
suspended due to suspicious activity. Verify
immediately:

http://absa-verify.co.za/unlock

Account will be permanently closed in 2 hours
if not verified.
```

**Red flags in this SMS:**

- ✗ Urgency + fear of account loss
- ✗ Fake domain (absa-verify.co.za)
- ✗ Sent from generic number, not ABSA shortcode
- ✗ No personalisation — 'your account'
- ✗ 2-hour deadline to create panic

✅ Your bank will NEVER ask you to click a link in an SMS to verify or unblock your account. Call the number on the back of your card.

# Vishing: Phone-Based Social Engineering

**TYPICAL VISHING SCRIPT — READ THIS AND YOU'LL RECOGNISE IT INSTANTLY**

| | |
|---|---|
| **ATTACKER:** | 'Good morning, I'm calling from FNB Fraud Prevention. My name is James from the Johannesburg office. Badge number 47821.' |
| **YOU:** | '...okay?' |
| **ATTACKER:** | 'We've detected suspicious activity on your account — someone in Cape Town just tried to transfer R12,000. Did you authorise this?' |
| **YOU:** | 'No!' |
| **ATTACKER:** | 'Don't worry, I can reverse it immediately, but I need to verify it's you. Can you confirm your card number and the OTP we're sending you now?' |

🛑 STOP: Hang up. Call the official bank number yourself. Never give your OTP to anyone who calls you — including someone claiming to be IT, SAPS, or your CEO.

SECTION 4

# What To Do If You're Targeted

# You Receive a Suspicious Email — What Now?

## STOP

Don't click any links or open attachments. Don't reply.

## THINK

Does this email make sense? Were you expecting it? Check sender domain carefully.

## VERIFY

If unsure, contact the sender directly using a known phone number — NOT by replying to the email.

## REPORT

Forward to your security team or use the 'Report Phishing' button. Even if you're not sure — report it.

## DOCUMENT

Note the time, sender, and what you did. This helps the security team respond faster.

⚠️ **IF YOU CLICKED a link or opened an attachment:** Disconnect from Wi-Fi immediately. Call IT Security NOW. Do not try to fix it yourself.

# How to Report a Phishing Attempt

### 📧 Forward the Email

Forward the suspicious email to your designated security reporting address (e.g. security@yourcompany.com). Include the original as an attachment if possible to preserve headers.

### 🔘 Use Report Phishing Button

In Microsoft Outlook: Select email → Report Message → Phishing. In Gmail: Three dots menu → Report phishing. This also alerts Microsoft/Google.

### 📞 Call IT Security Directly

If you clicked a link or opened an attachment — call the IT Security hotline immediately. This is time-critical.

### 📝 Log it in the Incident Register

All security incidents must be logged per the Incident Response Plan. Even near-misses help identify attack campaigns.

SECTION 5

# POPIA & Your Legal Obligations

# Why Phishing is a POPIA Issue

LEGAL

## POPIA Act 4 of 2013

Requires your organisation to implement appropriate **technical and organisational measures** to protect personal information from loss, damage, and unauthorised access.

→ The organisation may be required to notify the Information Regulator

→ Affected data subjects (customers, employees) must be notified

→ Fines up to R10 million or imprisonment up to 10 years

→ Reputational damage — loss of client trust

→ You personally may face disciplinary action

## Your obligations as an employee:

- ✓ Handle personal information with care
- ✓ Never share login credentials
- ✓ Report suspected breaches immediately
- ✓ Do not send PI via unencrypted email
- ✓ Lock your screen when away from desk
- ✓ Follow the Data Classification Policy
- ✓ Complete mandatory security training annually

# Cybercrimes Act 19 of 2020

SA LAW

**The Cybercrimes Act makes phishing-related activities CRIMINAL OFFENCES in South Africa**

s.2

### Unlawful access to computer systems

Someone using phishing to access your company's systems commits a crime — and so does any insider who assists.

s.4

### Unlawful interception of data

Capturing login credentials or personal data via fake login pages is a criminal offence.

s.8-9

### Fraud and extortion

BEC attacks and ransomware following phishing compromise are prosecutable under the Act.

s.54

### Reporting obligations for financial institutions

Banks and financial service providers must report cyber incidents to the SAPS.

SECTION 6

# Test Your Knowledge

# Quick Knowledge Check — 4 Questions

Q1: You receive an email from 'HR@yourcompany-hr.co.za' asking you to urgently update your banking details. You should:

- **A** Click the link and update your details immediately — HR wouldn't ask unless urgent
- **B** Verify by calling HR directly using the number in the company directory
- **C** Forward it to your manager and wait
- **D** Reply to the email asking if it's genuine

Q2: You accidentally clicked a link in a suspicious email. You should FIRST:

- **A** Close the browser and hope for the best
- **B** Change your password immediately
- **C** Disconnect from Wi-Fi/network and contact IT Security immediately
- **D** Run a full virus scan

# Your 6 Golden Rules — Take These Away

**1**

### Stop before you click

Pause. One second of thought prevents hours of breach response.

**2**

### Check the sender domain

Display names lie — always check the actual email address behind the name.

**3**

### Never share OTPs or passwords

No legitimate organisation will ever ask for these — not IT, not your bank, not SAPS.

**4**

### Hover before you click links

Check the real URL before clicking anything in an email or SMS.

**5**

### Report, don't delete

Forward suspicious emails to security. Near-misses help us protect everyone.

**6**

### If in doubt, verify out-of-band

Call the person/organisation using a number YOU looked up — not one provided in the suspicious message.

# Training Complete

*Questions? Contact IT Security or speak to your line manager.*

📞 **IT Security Incident Hotline:** [Your IT Security Number]

📧 **Report Phishing:** security@[yourcompany.com]

🌐 **Greyhat4Hire IR Retainer:** +27 84 635 3581 | www.greyhat4hire.com

Please complete the sign-off sheet confirming you have attended this training session. Your signature confirms understanding of your POPIA and security obligations.